Prediction Task

Dirk Riehle, FAU Erlangen
Professorship for Open-Source Software

PCOM A02

Licensed under CC BY 4.0 International

This Semester’s Task [1]

Design and implement an algorithm that can

- Predict future vulnerability scores of open source packages

[1] At the beginning of the course, the task is kept general deliberately

Domain Glossary

CVE. Common Vulnerabilities and Exposures.

- A record describing a known vulnerability or exposure
- CVE id. An id for a vulnerability or exposure in the form of CVE-2024-3385

CVSS. Common Vulnerability Scoring System.

- Value type from 0 to 10 in 0.1 steps signifying the criticality of a vulnerability
- CVSS Score. A value from the CVSS value type
  - 0.0 = none;
  - 0.1-3.9 = low
  - 4.0-6.9 = medium
  - 7.0-8.9 = high
  - 9.0-10.0 = critical

PURL. Package URL, see https://github.com/package-url/purl-spec

Datasets

Dataset you create

- Training data (70%)
- Validation data (15%)
- Test data (15%)

Dataset we create

- Prediction data

Prediction Input (Illustration)

A corpus of open source package data where for each package the data

- Consists of a time series of versions and
  - Where each version contains
    - Historical data, raw or computed
    - Associated vulnerability distribution

Prediction Output (Illustration)

The vulnerability distribution for the next version of an open source package



Thank you! Any questions?

dirk.riehle@fau.de – https://oss.cs.fau.de

dirk@riehle.org – https://dirkriehle.com – @dirkriehle

Legal Notices

License

- No license given; please ask for permission before distributing

Copyright

- © 2026 Dirk Riehle, all rights reserved